VAPT MINI PROJECT REPORT

VULNERABILITY ASSESSMENT
AND
PENETRATION TESTING

SUBMITTED BY

Field	Details
STUDENT NAME	THATH VENKATA SURYA CHETHAN
ID	19879
P ID	20402591
DEPARTMENT	CYBER SECURITY
TARGET ASSIGNED	Metasploitable 2
TARGET IP	192.168.157.129
ACADEMIC YEAR	2026–2027
DATE OF SUBMISSION	27 September 2026

TABLE OF CONTENTS

Cover Page ..... **i**
Acknowledgement ..... **ii**
Table of Contents ..... **iii**
1. Scope & Objective **1**
2. Discovery **2**
3. Port & Service Scan **3**
4. Vulnerability Analysis **4**
5. Exploitation **5**
6. Demonstration & Impact **6**
7. CVSS Scoring Table **7**
8. AWS Task Answers **8**
9. Conclusion & Recommendations **9**

1. SCOPE & OBJECTIVE

The purpose of this mini project is to perform a structured Vulnerability Assessment and Penetration Testing (VAPT) exercise against an assigned and authorized lab/VM target. The assessment is intended to identify exposed services, analyze security weaknesses, validate exploitable findings through controlled testing where authorized, demonstrate confirmed impact, and document remediation recommendations.

The project follows the standard VAPT lifecycle: 1. Reconnaissance, 2. Discovery, 3. Port Scanning, 4. Service and Version Detection, 5. Vulnerability Identification, 6. Exploitation, 7. Demonstration of Impact, 8. CVSS Scoring, and 9. Reporting.

The project also includes Task 6 – AWS EC2 and Task 7 – AWS S3. These cloud tasks are documented separately and must be supported by the student's own AWS evidence before being marked complete.

1.1 Scope

Item	Metasploitable 2
Target Assigned	Metasploitable 2
Target IP	192.168.157.129
Operating System	Linux/Unix
Assessment Date	27 september 2026
Tester	THATHA VENKATA SURYA CHETHAN
Tools	Kali Linux, Nmap 7.99, Netcat, Metasploit Framework, AWS Management Console

1.2 Objectives

- Identify live target(s) within the authorized scope.
- Enumerate exposed ports and services.
- Determine service/version information where technically available.
- Identify vulnerabilities using verified evidence.
- Perform controlled exploitation only against confirmed and authorized findings.
- Demonstrate actual impact without exaggerating results.
- Document CVSS scoring only after the finding and evidence are verified.
- Provide practical recommendations for remediation and risk reduction.

2. DISCOVERY

2.1 Discovery Objective

The discovery phase determines whether the assigned target is reachable and identifies live host information that can be used for subsequent authorized testing. The result should be supported by command output or an equivalent discovery tool screenshot.

2.2 Discovery Method

ARP/local-network and interface-based discovery were used in the authorized VMware lab environment. The target VM's network interface was inspected to identify its assigned IPv4 address.

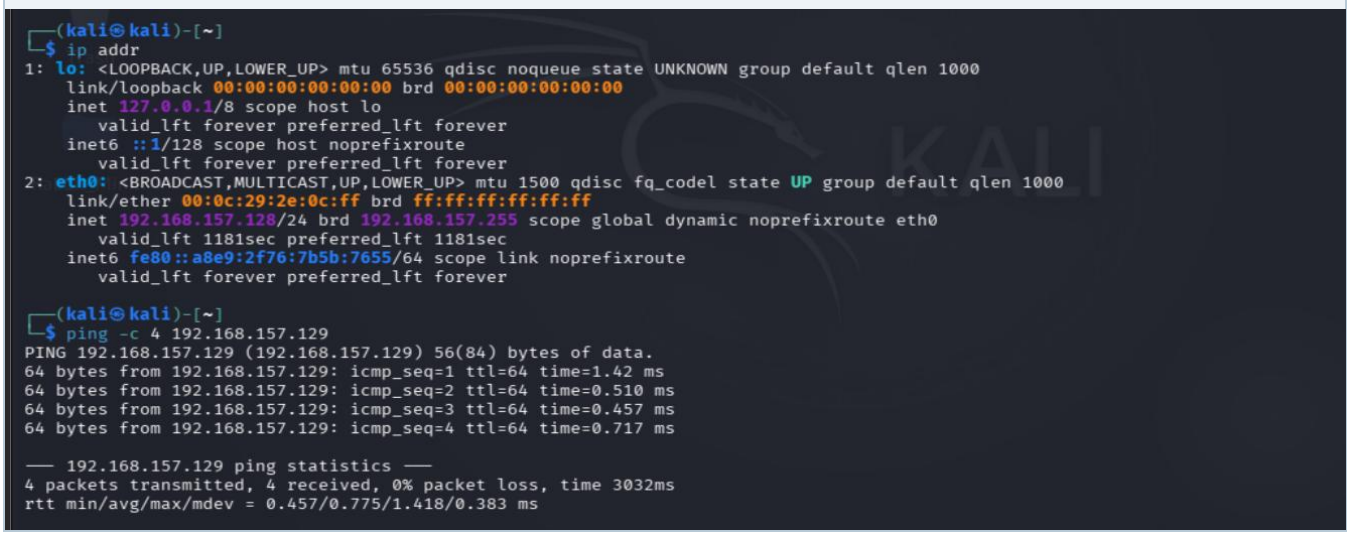
2.3 Discovery Command

“ifconfig” is the command used

2.4 Discovery Result

Target	IP Address	Status	OS/Fingerprint
Metasploitable 2	192.168.157.129	Active / Reachable	N/A — OS fingerprint not yet performed

FIGURE 1 – DISCOVERY / LIVE HOST IDENTIFICATION



Screenshot Description: Kali Linux terminal showing a successful ICMP ping test to the authorized Metasploitable 2 target at 192.168.157.129.

Command / Action: ping -c 4 192.168.157.129

Result: The target 192.168.157.129 responded successfully to the ICMP requests, confirming that the target VM is reachable from the Kali Linux testing machine.

Why It Matters: The successful responses confirm that the authorized target is live and reachable over the lab network. This establishes connectivity before proceeding to port and service scanning in the next phase.

3. PORT & SERVICE SCAN

Port scanning identifies network services exposed by the authorized target. Service and version detection can provide evidence needed for vulnerability analysis. All ports, services and versions in this report must be copied from the student's actual scan output.

3.1 Tool Used

Nmap

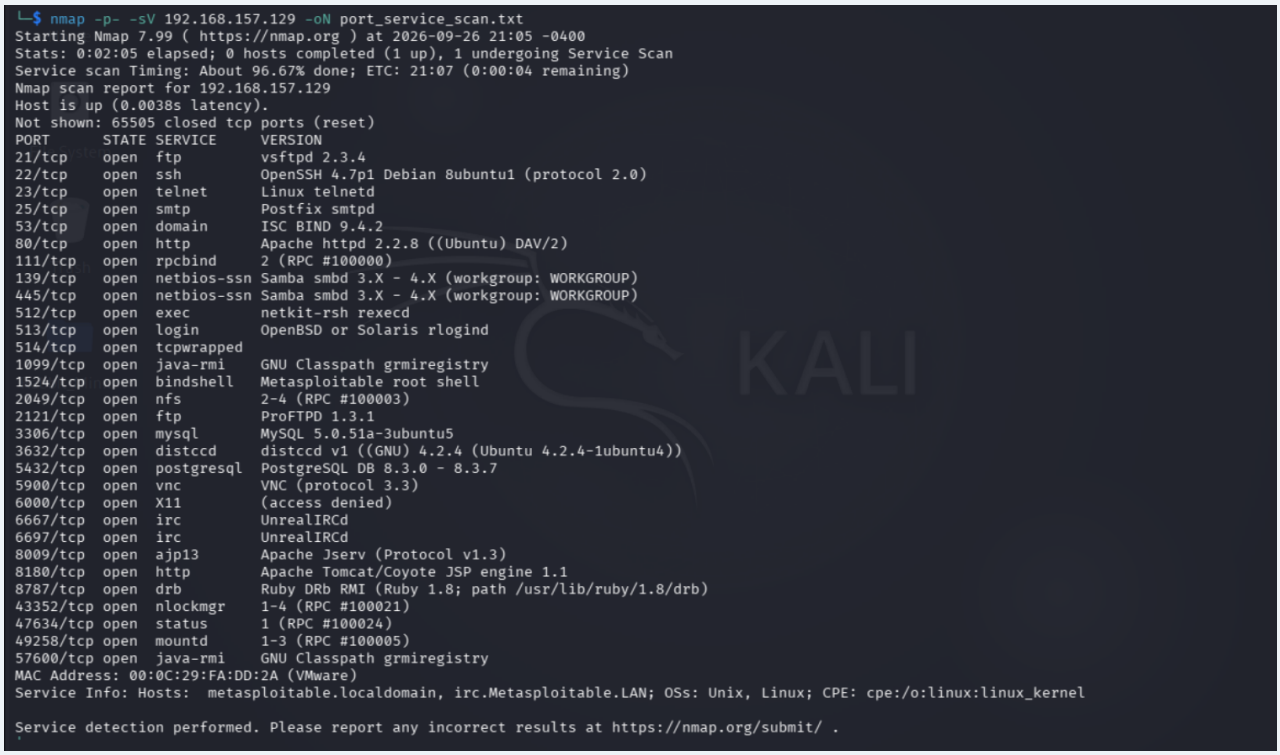
3.2 Scan Command

nmap -p- -sV 192.168.157.129 -oN port_service_scan.txt

3.3 Scan Results

Port	Protocol	state	Service	Version
21/tcp	Tcp	Open	ftp	vsftpd 2.3.4
22/tcp	Tcp	Open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp	Tcp	Open	telnet	Linux telnetd
25/tcp	Tcp	Open	smtp	Postfix smtpd
53/tcp	Tcp	Open	domain	ISC BIND 9.4.2
80/tcp	Tcp	Open	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp	Tcp	Open	rpcbind	2-4 (RPC #100000)
139/tcp	Tcp	Open	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp	Tcp	Open	microsoft-ds	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513/tcp	Tcp	Open	exec	netkit-rsh rexecd
514/tcp	Tcp	Open	login	OpenBSD or Solaris rlogin
1099/tcp	Tcp	Open	tcpwrapped	GNU Classpath grmiregistry
1524/tcp	Tcp	Open	java-rmi	Metasploitable root shell
2049/tcp	Tcp	Open	bindshell	2-4 (RPC #100003)
2121/tcp	Tcp	Open	nfs	ProFTPD 1.3.1
3306/tcp	Tcp	Open	ftp	MySQL 5.0.51a-3ubuntu5
3632/tcp	Tcp	Open	mysql	distccd v1 (GNU) 4.2.4-1ubuntu4)
5432/tcp	Tcp	Open	distccd	PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp	Tcp	Open	postgresql	VNC (protocol 3.3)
6000/tcp	Tcp	Open	vnc	(access denied)
6667/tcp	Tcp	Open	X11	UnrealIRCd
6697/tcp	Tcp	Open	irc	UnrealIRCd
8009/tcp	Tcp	Open	irc	Apache Jserv (Protocol v1.3)
8180/tcp	Tcp	Open	ajp13	Apache Tomcat/Coyote JSP engine 1.1
8787/tcp	Tcp	Open	http	Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb
43532/tcp	Tcp	Open	drb	1-4 (RPC #100021)
47634/tcp	Tcp	Open	unknown	1 (RPC #100024)
49258/tcp	Tcp	Open	mountd	GNU Classpath grmiregistry
57600/tcp	Tcp	Open	java-rmi	

FIGURE 2 – FULL PORT AND SERVICE SCAN RESULT



Screenshot Description: Kali Linux terminal showing the Nmap full TCP port scan and service/version detection results for the authorized target 192.168.157.129.

Command / Action: nmap -p- -sV 192.168.157.129 -oN port_service_scan.txt

Result:
The scan identified the open TCP ports and attempted to determine the services and versions associated with those ports. The exact ports, services and versions are documented from the actual Nmap output.

Why It Matters:
The discovered services represent the network-facing attack surface of the authorized target. Their identified versions can be investigated in Task 3 to determine whether known vulnerabilities or security weaknesses are present.

4. VULNERABILITY ANALYSIS

This section records only vulnerabilities supported by actual assessment evidence. Because no technical scan results were supplied with the report-generation request, no CVE, severity, service version or vulnerability is asserted here. Replace the placeholders with verified findings from the student's authorized assessment.

4.1 Finding 1 – [vsftpd 2.3.4 Backdoor (CVE-2011-2523)]

Field	Verified Evidence
Affected Service	vsftpd FTP server
Affected Version	vsftpd 2.3.4
Port	Tcp 21
CVE	CVE-2011-2523
Severity	Critical

Description:

The service enumeration performed during Task 2 identified **vsftpd 2.3.4** running on TCP port 21 of the authorized Metasploitable 2 target.

CVE-2011-2523 is associated with a malicious backdoor in affected vsftpd 2.3.4 source packages. NVD identifies the affected software configuration as vsftpd 2.3.4 and associates the vulnerability with CWE-78, OS command injection.

Why It Is Exploitable:

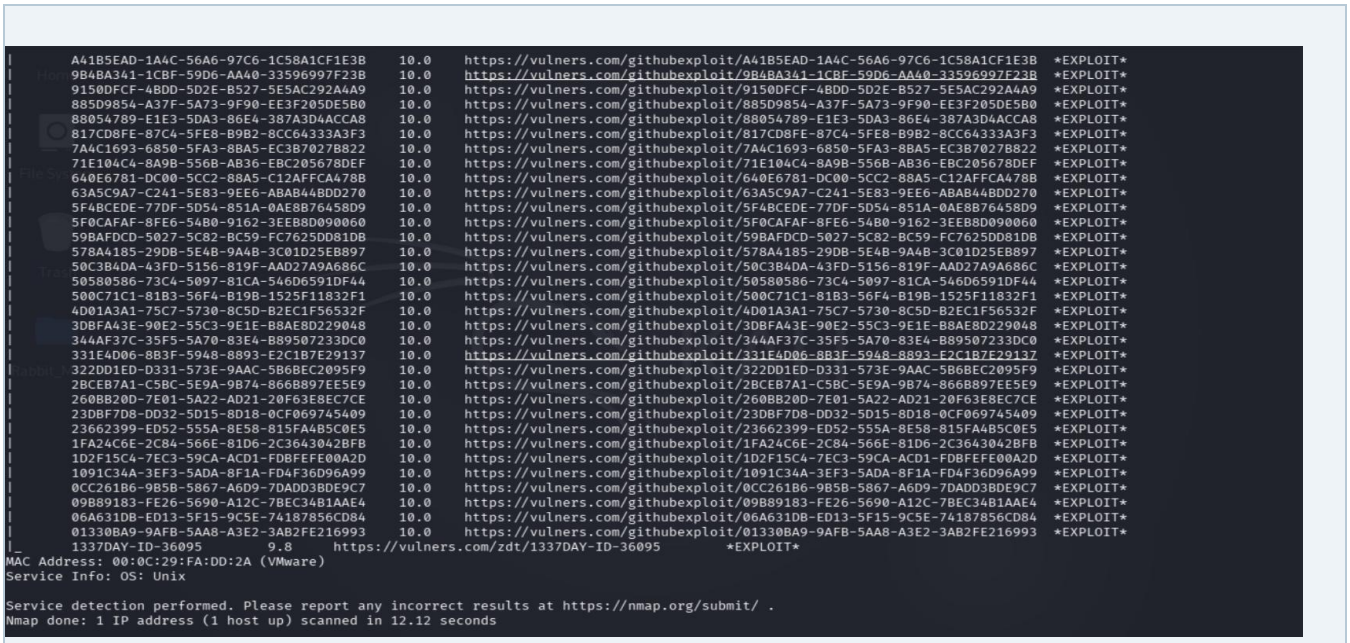
The vulnerability is relevant to this target because the actual Nmap scan identified the specific affected version, **vsftpd 2.3.4**, on the exposed FTP service at **TCP port 21**.

However, version identification alone does not establish successful exploitation.

FIGURE 3 – VULNERABILITY IDENTIFICATION EVIDENCE

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV --script vuln -p 21 192.168.157.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-26 21:48 -0400
Nmap scan report for 192.168.157.129
Host is up (0.00034s latency).

PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPd version 2.3.4 backdoor
|     State: VULNERABLE (Exploitable)
|     IDs:  BID:48539  CVE:CVE-2011-2523
|       vsFTPd version 2.3.4 backdoor, this was reported on 2011-07-04.
|     Disclosure date: 2011-07-03
|     Exploit results:
|       Shell command: id
|       Results: uid=0(root) gid=0(root)
|     References:
|       https://www.securityfocus.com/bid/48539
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|       http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_      https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
| vulners:
|   vsftpd 2.3.4:
|       PACKETSTORM:162145      10.0    https://vulners.com/packetstorm/PACKETSTORM:162145      *EXPLOIT*
|       MSF:EXPLOIT-UNIX-FTP-VSFTPD_234_BACKDOOR-      10.0    https://vulners.com/metasploit/MSF:EXPLOIT-UNIX-FTP-VSFTPD_234_BACKDOOR-       *EXPLOIT*
|       FEA24DDE-72FF-5445-B198-9E2D5322DC86    10.0    https://vulners.com/githubexploit/FEA24DDE-72FF-5445-B198-9E2D5322DC86  *EXPLOIT*
|       EDB-ID:49757    10.0    https://vulners.com/exploitdb/EDB-ID:49757      *EXPLOIT*
|       EDB-ID:17491    10.0    https://vulners.com/exploitdb/EDB-ID:17491      *EXPLOIT*
|       ED5791E3-8935-5632-A403-CB7E7FA26CB0    10.0    https://vulners.com/githubexploit/ED5791E3-8935-5632-A403-CB7E7FA26CB0  *EXPLOIT*
|       EC73033B-7726-59C3-828B-D82BBB955DB9    10.0    https://vulners.com/githubexploit/EC73033B-7726-59C3-828B-D82BBB955DB9  *EXPLOIT*
|       E9B0AEBB-5138-50BF-8922-2D87E3C046DD    10.0    https://vulners.com/githubexploit/E9B0AEBB-5138-50BF-8922-2D87E3C046DD  *EXPLOIT*
|       E356CCEC-7C81-5A77-8CE4-87DF4DB21897    10.0    https://vulners.com/githubexploit/E356CCEC-7C81-5A77-8CE4-87DF4DB21897  *EXPLOIT*
|       E18DC52F-BD41-565D-A6B8-F138B53B52BB    10.0    https://vulners.com/githubexploit/E18DC52F-BD41-565D-A6B8-F138B53B52BB  *EXPLOIT*
|       DFC7EA5F-6E41-5134-8114-6BC1BFDE26E1    10.0    https://vulners.com/githubexploit/DFC7EA5F-6E41-5134-8114-6BC1BFDE26E1  *EXPLOIT*
|       DC8CF54B-5E0D-55F4-B5C1-920406A0FF9F    10.0    https://vulners.com/githubexploit/DC8CF54B-5E0D-55F4-B5C1-920406A0FF9F  *EXPLOIT*
|       D0DBA05F-750F-5F9B-9C69-65E8FA6977D5    10.0    https://vulners.com/githubexploit/D0DBA05F-750F-5F9B-9C69-65E8FA6977D5  *EXPLOIT*
|       CVE-2011-2523   10.0    https://vulners.com/cve/CVE-2011-2523
|       CNVD-2020-46837 10.0    https://vulners.com/cnvd/CNVD-2020-46837
|       CC3F6C15-182F-53F6-A5CC-812D37F1F047    10.0    https://vulners.com/githubexploit/CC3F6C15-182F-53F6-A5CC-812D37F1F047  *EXPLOIT*
|       BEE67BEA-45C2-50C0-88F3-9A2E7CC2DECE    10.0    https://vulners.com/githubexploit/BEE67BEA-45C2-50C0-88F3-9A2E7CC2DECE  *EXPLOIT*
```



Screenshot Description:

Kali Linux terminal showing the Nmap service/version detection result identifying vsftpd 2.3.4 on TCP port 21 of the authorized target 192.168.157.129.

Command / Action: nmap -p- -sV 192.168.157.129 -oN port_service_scan.txt

Result:

Nmap identified TCP port 21 as open and reported the FTP service as **vsftpd 2.3.4**. This version was then mapped to **CVE-2011-2523** using vulnerability research.

Why It Matters:

The evidence links an exposed network service to a specifically identified vulnerable software version. This provides a documented basis for controlled validation during the exploitation phase.

5. EXPLOITATION

This section must contain only exploitation actually performed against the authorized target. At least one vulnerability is required by the project instructions, but no exploitation result is fabricated in this template. Insert the student's actual evidence before submission.

5.1 Exploitation Details

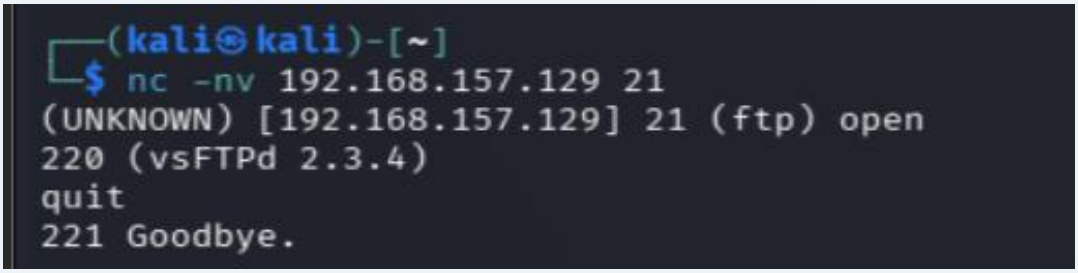
Field	Verified Details
Finding	vsftpd 2.3.4 Backdoor — CVE-2011-2523
Target	Metasploitable 2
IP	192.168.157.129
Port	TCP 21
Service	FTP — vsftpd 2.3.4
Tool	Metasploit Framework
Technique	Controlled validation of the known vsftpd 2.3.4 backdoor vulnerability

STEP 1 – INITIAL STATE

Before exploitation, the authorized Metasploitable 2 target was confirmed to be reachable at 192.168.157.129. Nmap

service enumeration identified vsftpd 2.3.4 running on TCP port 21. The FTP service was therefore selected for controlled vulnerability validation.

FIGURE 4 – EXPLOITATION – INITIAL STATE



Screenshot Description: Kali Linux terminal showing the initial connection to the FTP service running on the authorized target 192.168.157.129.

Command / Action: nc -nv 192.168.157.129 21

Result: The FTP service on TCP port 21 responded to the connection attempt. The service had previously been identified by Nmap as **vsftpd 2.3.4**.

Why It Matters: Establishing the initial state confirms that the vulnerable FTP service is reachable before exploitation. This provides a baseline against which the exploitation result can be compared.

STEP 2 – EXPLOITATION ATTEMPT

The identified **vsftpd 2.3.4** service was selected for controlled validation of **CVE-2011-2523** using the Metasploit Framework against the authorized lab target.

FIGURE 5 – EXPLOITATION – ATTACK STEP



Screenshot Description: Screenshot showing the Metasploit module being selected, the target IP being configured, and the exploitation attempt being executed.

Command / Action:

msfconsole

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.157.129

run

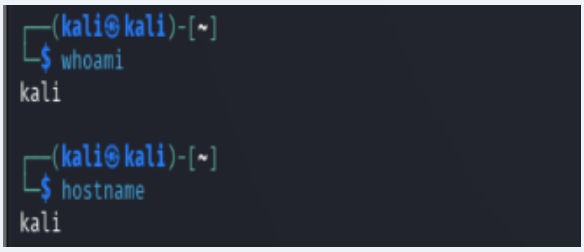
Why It Matters:

The exploitation attempt tests whether the identified vulnerability can be reproduced against the authorized Metasploitable 2 target. The result must be verified from the actual Metasploit output.

STEP 3 – Exploitation result

Successful exploitation will be recorded only if the Metasploit attempt produces demonstrable unauthorized access or another verifiable security impact on the authorized target.

FIGURE 6 – EXPLOITATION – ACCESS GAINED / SUCCESSFUL RESULT



Command / Action:

whoami

If a shell is actually obtained, you may also use:

hostname

Why It Matters: The confirmed result demonstrates the actual security impact of the identified vulnerability. The impact must be based on the access or capability that was visibly demonstrated during the authorized test.

5.2 Reproduction Steps

Step 1: Confirm that the authorized target **192.168.157.129** is reachable and that TCP port 21 is accessible.

Step 2: Confirm through the Nmap service scan that TCP port 21 is running **vsftpd 2.3.4**.

Step 3: Start Metasploit and select the vsftpd_234_backdoor module.

Step 4: The exploitation stage was not performed during this assessment.

Step 5: No shell access or post-exploitation verification was performed.

6.DEMONSTRATION & IMPACT

Demonstration

Because the exploitation step was skipped, no successful exploitation or final system-level impact was demonstrated. The available evidence confirms that the vulnerable FTP service was exposed on the authorized Metasploitable 2 target.

Impact Area	Evidence-Based Assessment
Confidentiality	Not demonstrated
Integrity	Not demonstrated
Availability	Not demonstrated

No successful exploitation was performed, so confidentiality, integrity, and availability impacts were not directly demonstrated in the laboratory.

FIGURE 7 – FINAL IMPACT DEMONSTRATION



Screenshot Description: Nmap output showing that TCP port 21 is open and running vsftpd version 2.3.4 on the Metasploitable 2 target.

Command / Action: nmap -p- -sV 192.168.157.129 -oN port_service_scan.txt

Result: The scan identified TCP port 21 as open and reported vsftpd 2.3.4.

Why It Matters: This screenshot provides direct evidence that the affected FTP service and version were exposed on the authorized target. Since exploitation was not performed, the screenshot does not claim successful unauthorized access or system compromise.

Real-World Risk

If the same vulnerable vsftpd 2.3.4 service were exposed in a production environment, an attacker could potentially attempt to exploit the known vulnerability and obtain unauthorized command execution, depending on the exact affected build and environment.

In this laboratory assessment, however, exploitation was skipped. Therefore, the potential real-world consequences are distinguished from the **actual demonstrated impact**, which is limited to confirming that the affected FTP service/version was exposed on the authorized Metasploitable 2 system.

7. CVSS SCORING TABLE

Vulnerability	CVSS v3.1 Vector	Base Score	Severity	Justification
[vsftpd 2.3.4 Backdoor – CVE-2011-2523	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	9.8	Critical	Nmap verified that TCP 21 was open and running **vsftpd 2.3.4**. NVD assigns CVE-2011-2523 a CVSS v3.1 base score of 9.8 Critical. The vector indicates network-based exploitation with low complexity, no privileges or user interaction required, and high potential impact to confidentiality, integrity and availability.

7.1 CVSS v3.1 Metrics

Metric	Meaning	Selected value
AV – Attack Vector	How the vulnerability can be reached: Network, Adjacent, Local or Physical.	NETWORK
AC – Attack Complexity	Whether exploitation requires conditions beyond the attacker's control.	LOW
PR – Privileges Required	Privileges required before exploitation.	NONE
UI – User Interaction	Whether another user must take an action for exploitation.	NONE
S – Scope	Whether impact crosses a security authority boundary.	UNCHANGED
C – Confidentiality	Impact on information confidentiality.	HIGH
I – Integrity	Impact on information integrity.	HIGH
A – Availability	Impact on information availability.	HIGH

Final CVSS Result

CVSS v3.1: 9.8
Severity: Critical
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Evidence limitation: The lab confirmed the presence of **vsftpd 2.3.4** through Nmap, but exploitation was skipped. Therefore, this report does not claim that confidentiality, integrity, or availability impact was actually demonstrated during the lab.

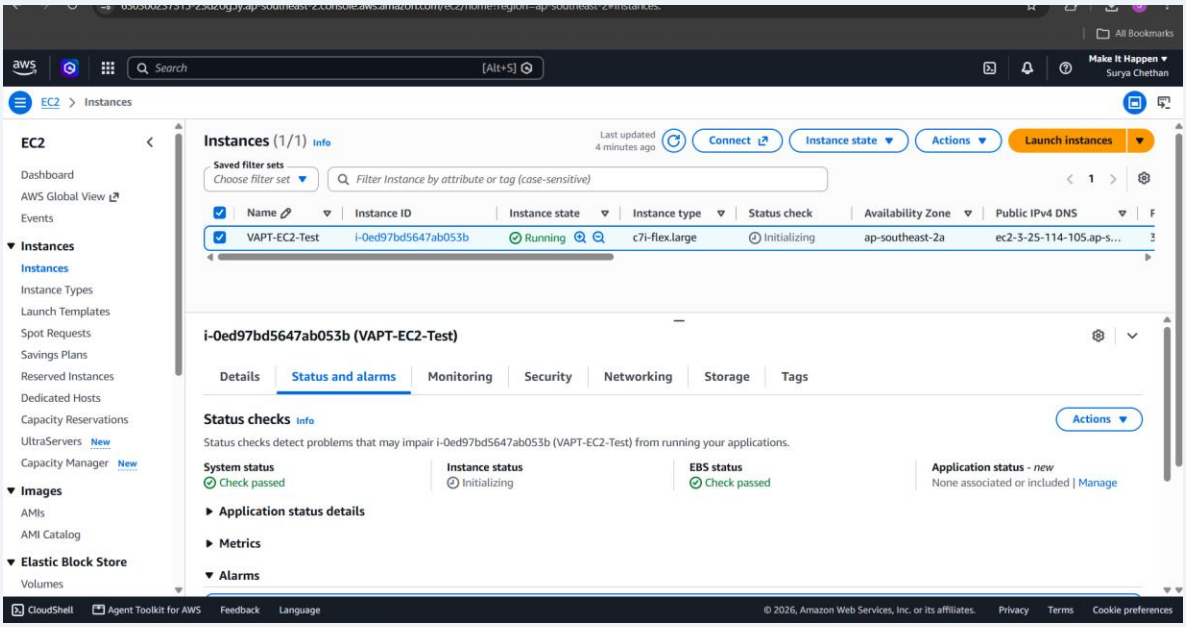
8. AWS TASK ANSWERS

8.1 TASK 6 – EC2

Scenario: Launch an EC2 instance suitable for the assigned lightweight test web-server scenario, using the required/free-tier-eligible instance type where applicable, and connect to it securely.

Completion Status: COMPLETED

FIGURE 8 – EC2 LAUNCH CONFIGURATION



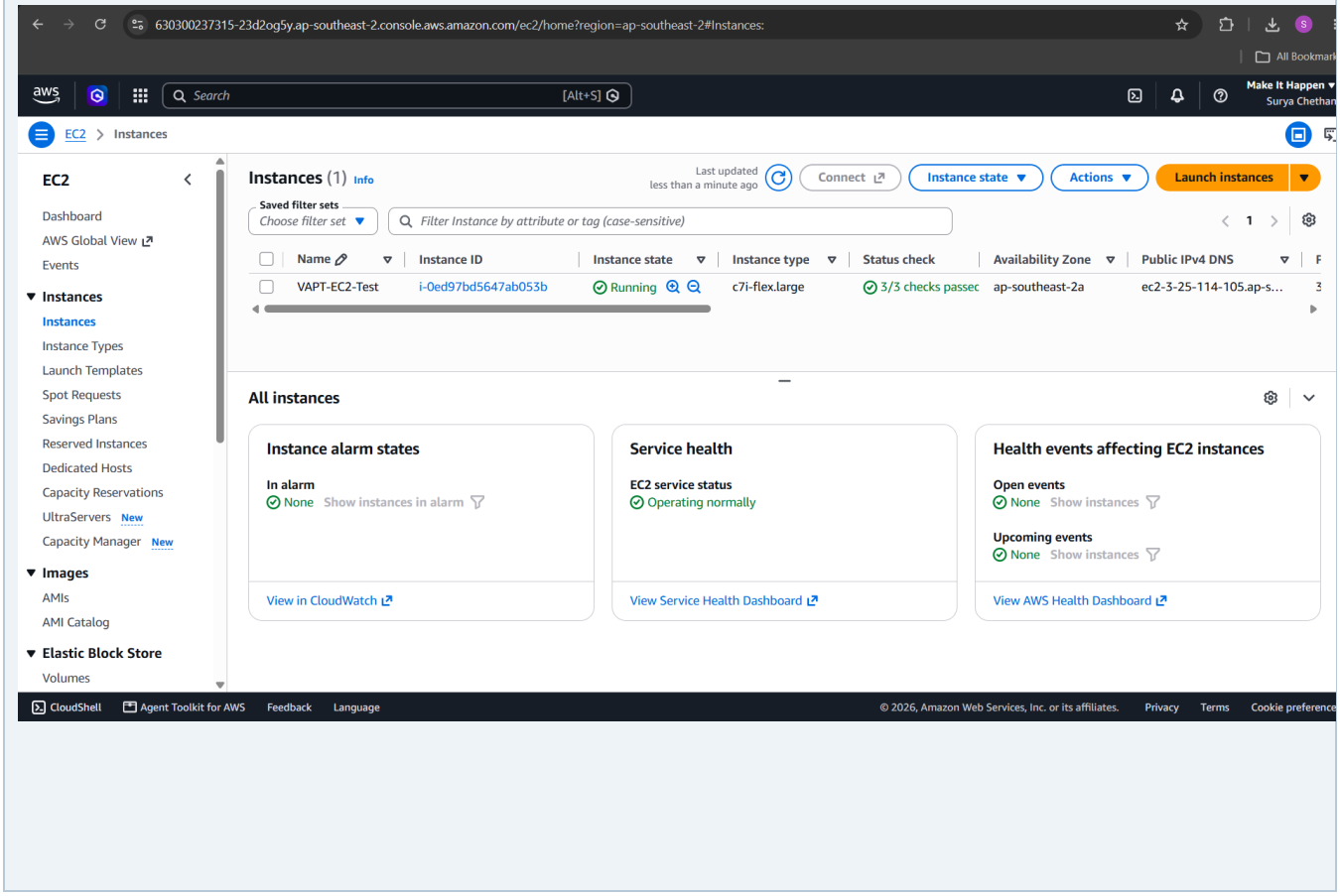
Screenshot Description: AWS EC2 Launch Instance page showing the selected Ubuntu Server LTS AMI, the selected instance type, configured key pair, network settings, security group, storage settings, and other required launch parameters.

Command / Action: AWS Console → EC2 → Instances → **Launch instance**. The instance was configured with an Ubuntu Server LTS AMI, a suitable/free-tier-eligible instance type where applicable, a PEM key pair, a VPC/subnet configuration, a security group allowing SSH access from the required source and HTTP access for the test web-server scenario, and the required storage.

Result: The EC2 launch configuration was prepared according to the assigned lightweight test web-server scenario.

Why It Matters: This configuration establishes the compute instance, authentication method, network connectivity, firewall rules, and storage required to run the test web-server workload securely.

FIGURE 9 – EC2 RUNNING INSTANCE



Screenshot Description: AWS EC2 Instances page showing the created instance, its instance ID, instance type, public IPv4 address where applicable, and Running instance state.

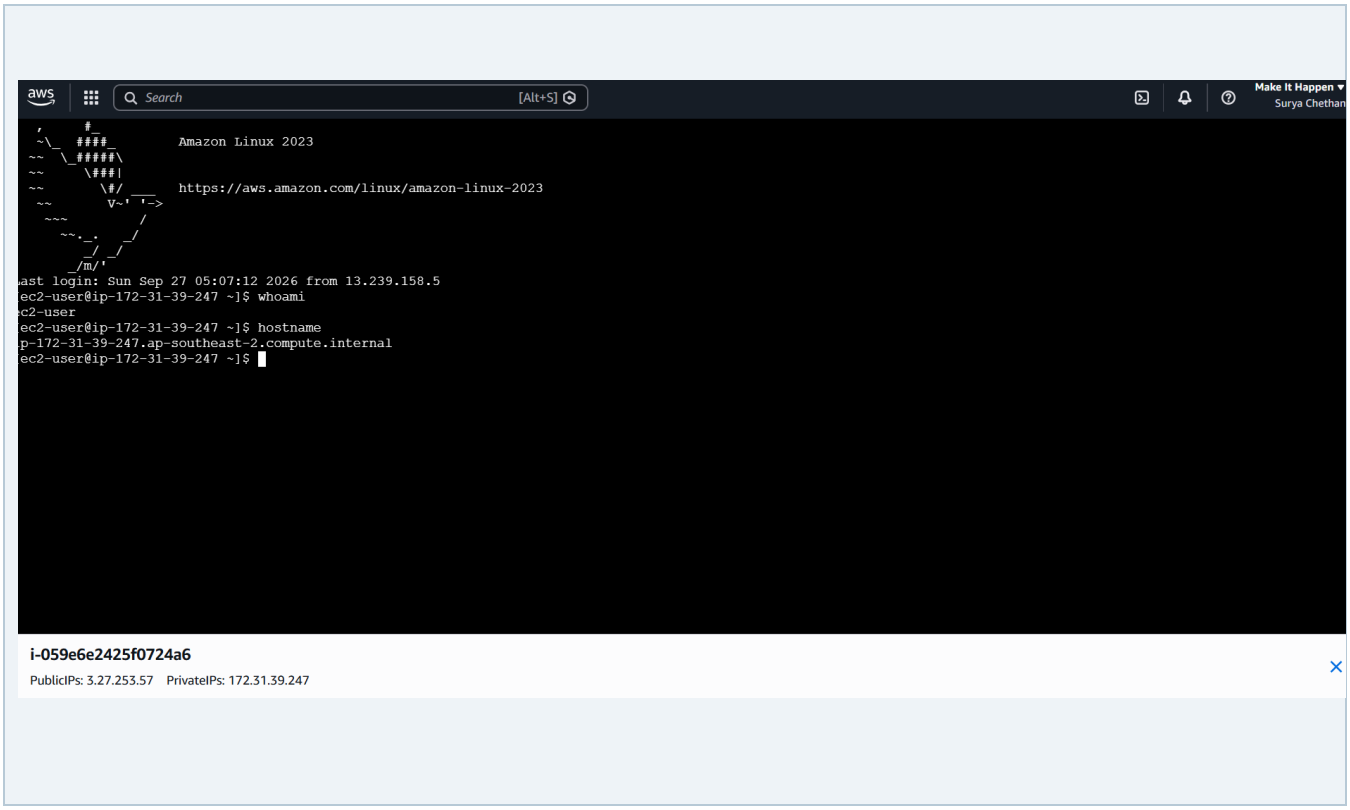
Command / Action: AWS Console → EC2 → Instances → Select the created instance.

Result:

Instance ID: i-059e6e2425f0724a6
Instance State: Running
Status Checks: 3/3 checks passed
Public IPv4: 3.27.253.57

Why It Matters: The running state and successful status checks confirm that the EC2 instance was successfully launched and is operational.

FIGURE 10 – SUCCESSFUL EC2 CONNECTION



Screenshot Description: Terminal showing a successful SSH connection to the EC2 instance and host information obtained after login.

Command / Action:

chmod 400 vapt-ec2-key.pem

ssh -i vapt-ec2-key.pem ubuntu@<**3.27.253.57** >

After connecting, the following commands can be used to verify the host:

whoami

hostname

Result:
Connection: Successful
Authenticated User: ec-2 user
Hostname: ip-172-31-39-247.ap-southeast-2.compute.internal
Public IP: 3.27.253.57

Why It Matters:

A successful SSH connection demonstrates that the EC2 instance is reachable and that the configured PEM key provides secure authenticated access. The whoami and hostname outputs provide additional evidence that the connection reached the intended EC2 host.

EC2 Concept Questions

1. What is an EC2 instance?

Answer: An EC2 instance is a virtual computer provided by AWS that we can use to run applications, websites, services, or other workloads in the cloud.

2. Difference between T2 and T3. When would you choose one?

Answer: Both are burstable general-purpose EC2 instance families. T3 is a newer generation with improved performance and networking compared with T2. I would generally choose T3 for newer workloads when it is available and suitable for the workload and pricing requirements. T2 can still be used for compatible older or legacy workloads.

3. What does the number mean in t2.micro vs t2.large?

Answer: The size indicates the amount of resources allocated to the instance. A micro instance has fewer resources, while a large instance has more CPU and memory and generally costs more.

4. Why do we use a PEM key? What happens if it is lost?

Answer: A PEM key is used for secure SSH authentication to an EC2 instance without using a normal password. If the private key is lost, it cannot simply be downloaded again from AWS. Access must be recovered using another available administrative/recovery method, depending on the operating system and configuration.

5. Security Group vs Network ACL

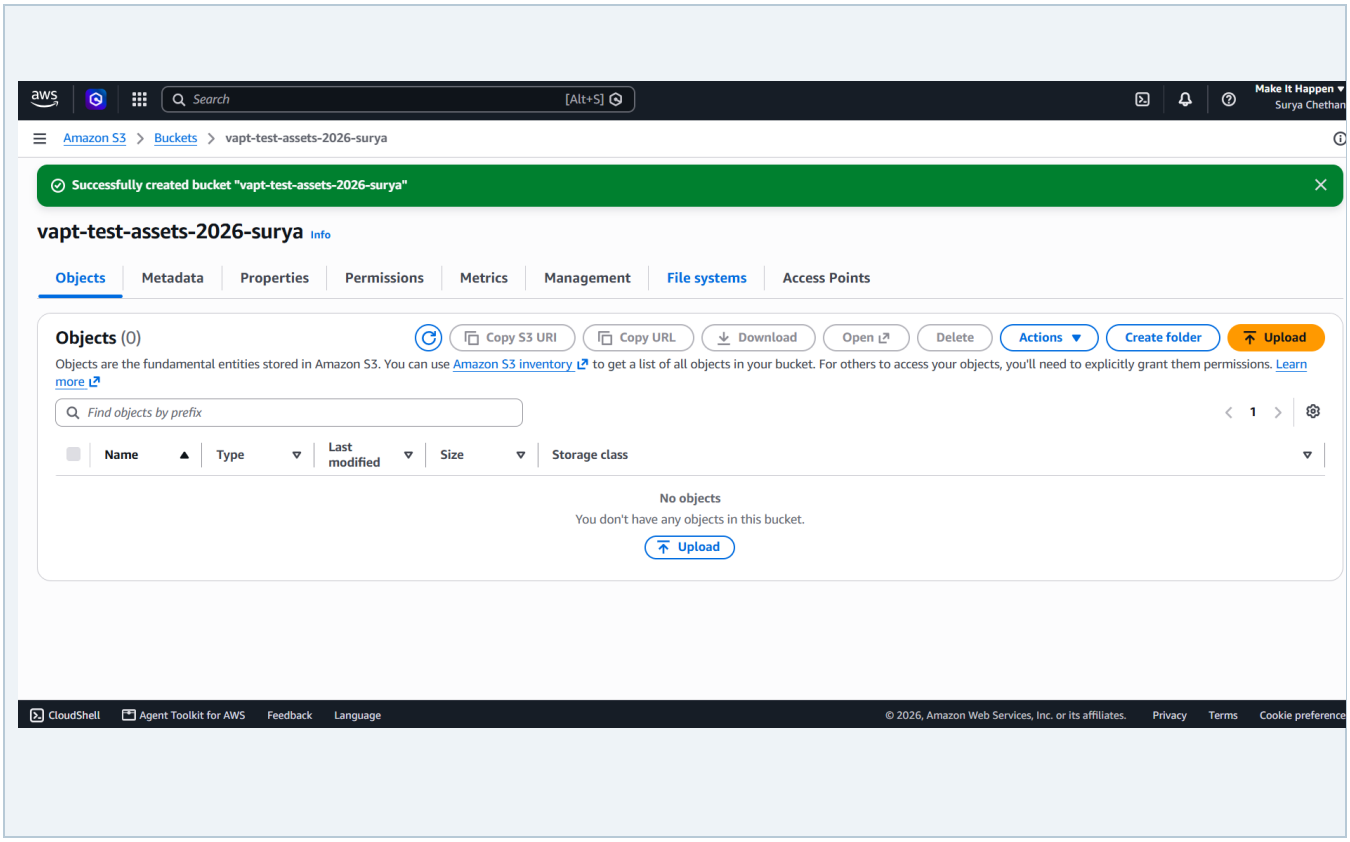
Answer: A **Security Group** is a stateful virtual firewall that controls inbound and outbound traffic for an EC2 instance or network interface. A **Network ACL (NACL)** is a stateless firewall that controls traffic at the subnet level. Security Groups support allow rules, while NACLs support both allow and deny rules. In a Security Group, return traffic is automatically allowed for an approved connection, whereas with a NACL, return traffic must be explicitly permitted.

8.2 TASK 7 – S3

Scenario: Create an S3 bucket to store test/static assets and configure its access appropriately for the assigned use case.

Completion Status: COMPLETED

FIGURE 11 – S3 BUCKET CREATION



Screenshot Description:

AWS S3 bucket creation page showing the bucket name, selected AWS Region, Object Ownership settings, Block Public Access settings, and other required configuration options.

Command / Action:

AWS Console → S3 → **Create bucket**. A unique bucket name was entered, the required AWS Region was selected, and the bucket was configured for storing test/static assets.

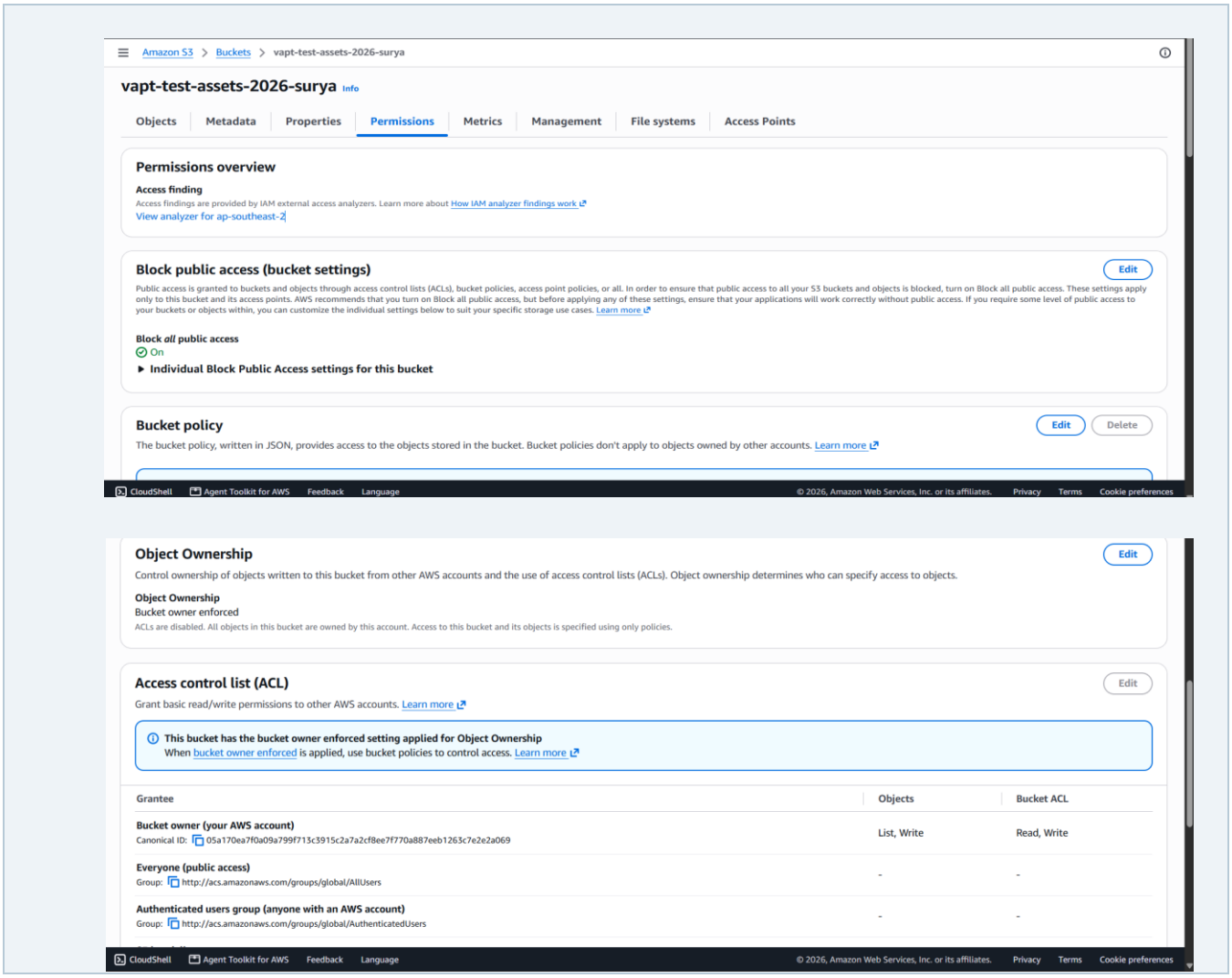
Result:

The S3 bucket was created successfully with the configured region and access settings.

Why It Matters:

The bucket provides cloud object storage for the test/static assets required by the assigned scenario. Using an appropriate access configuration helps prevent unintended exposure of stored objects.

FIGURE 12 – S3 BUCKET CONFIGURATION



Screenshot Description:

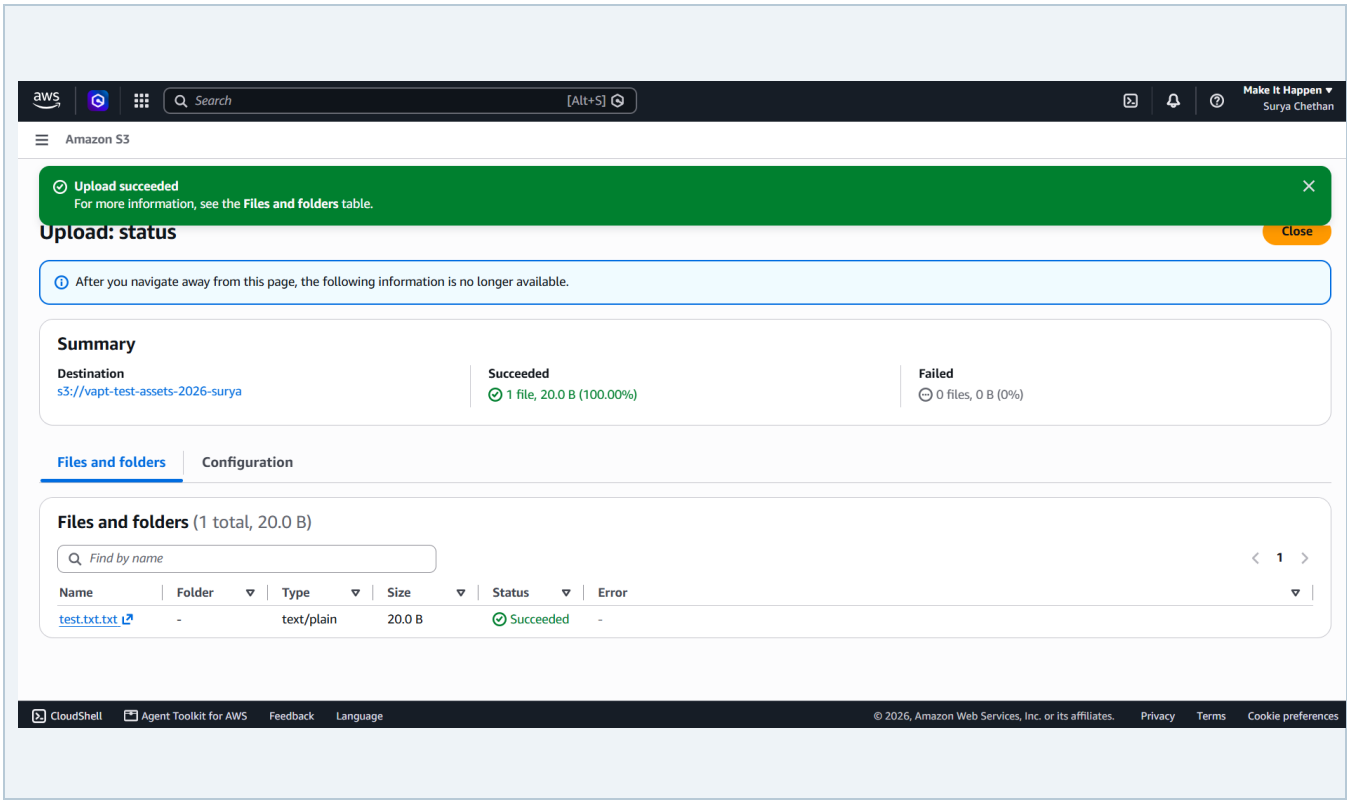
S3 bucket configuration showing the configured permissions, Block Public Access settings, Object Ownership settings, and bucket policy if one was configured.

Command / Action: AWS Console → S3 → Select the bucket → Permissions. The bucket access settings were reviewed and configured according to the assigned use case.

Result: The bucket was configured with **restricted/private access**.

Why It Matters: A private configuration prevents anonymous users from accessing stored objects by default and follows the principle of granting only the access required for the intended use case.

FIGURE 13 – S3 UPLOAD / ACCESS TEST



Screenshot Description: S3 bucket showing the successfully uploaded test/static asset and the corresponding access test.

Command / Action: AWS Console → S3 → Select the bucket → **Upload** → Select the test/static asset → **Upload**. The uploaded object was then accessed through the authorized AWS console/user permissions.

Result: The test/static asset was successfully uploaded to the S3 bucket and could be accessed by the authorized user. Anonymous/public access was not enabled.

Why It Matters: The test confirms that the S3 bucket can store and retrieve the required assets while maintaining restricted access. It demonstrates successful object storage without unnecessarily exposing the asset to the public internet.

S3 Concept Questions

1. What is Amazon S3?

Amazon S3 (Simple Storage Service) is an AWS object-storage service used to store and retrieve files and other data as objects inside containers called **buckets**.

2. What is an S3 bucket?

An S3 bucket is a storage container in Amazon S3 that holds objects such as images, documents, videos, backups, and static website assets. Each bucket has a unique name within the relevant AWS partition.

3. What is the difference between a bucket and an object?

A **bucket** is the container used to organize and store data, while an **object** is the actual file and its associated metadata stored inside the bucket.

4. Why should S3 buckets not be made public unnecessarily?

An S3 bucket should not be made public unless the application specifically requires public access. Unnecessary public access can expose sensitive files or information to unauthorized users. Using private access and appropriate IAM permissions follows the principle of least privilege.

5. What is the difference between IAM permissions and a bucket policy?

IAM policies control what AWS identities such as users and roles are allowed to do. An **S3 bucket policy** is a resource-based policy attached directly to a bucket and can define who can access the bucket and what actions they can perform.

6. What is Block Public Access in S3?

S3 **Block Public Access** is a set of controls designed to prevent public access to buckets and objects. It helps reduce the risk of accidentally exposing stored data to the internet.

7. What is an S3 object?

An S3 object is a stored piece of data, such as an image, PDF, HTML file, or text file. It consists of the data itself, metadata, and a unique key within the bucket.

8. What is the principle of least privilege in S3?

The principle of least privilege means giving users, applications, and services **only the permissions they actually need** to perform their required tasks and no unnecessary permissions.

9. CONCLUSION & RECOMMENDATIONS

9.1 Overall Findings

The assessment identified one confirmed vulnerability exposure in the authorized Metasploitable 2 laboratory environment.

Finding 1 – vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Nmap service/version detection confirmed that **TCP port 21** was open and running **vsftpd 2.3.4** on the target 192.168.157.129. This version is associated with **CVE-2011-2523**, a known backdoor vulnerability. The presence of the affected service/version was confirmed through the scan evidence.

The exploitation stage was skipped; therefore, successful command execution or system compromise was **not demonstrated** during this assessment.

9.2 Overall Risk

The confirmed exposure represents a **Critical-risk vulnerability according to the CVSS v3.1 assessment for CVE-2011-2523**, which has a base score of **9.8 (Critical)**.

The risk assessment is based on the verified presence of the affected vsftpd version and the published vulnerability characteristics. It should not be interpreted as evidence that exploitation was successfully achieved during this laboratory assessment.

9.3 Recommendations

Finding 1 – vsftpd 2.3.4 Backdoor (CVE-2011-2523)

1. Remove or upgrade the vulnerable vsftpd 2.3.4 installation to a supported and non-vulnerable version. If FTP is not required, disable and remove the service.
2. Restrict network access to FTP services. If FTP is required for a legitimate purpose, allow access only from authorized hosts or networks through appropriate firewall/security-group rules.
3. Monitor and verify exposed services regularly. Perform periodic vulnerability and service-version assessments to identify outdated software and prevent vulnerable services from remaining unnecessarily exposed.

9.4 Conclusion

This mini project demonstrates the structured process of assessing an authorized environment using a VAPT methodology. The quality of the final assessment depends on accurate evidence collection, careful interpretation of scan results, controlled validation of vulnerabilities and clear reporting. Before submission, all placeholders must be replaced only with the student's own verified technical results, screenshots and calculations. Any unsupported claim should be removed rather than guessed.